xVio Scan

Technical Solution Overview

xVio Scan is an AI-powered document scanning platform that transforms physical documents — business cards, invoices, receipts, ID documents, handwritten notes, forms, and contracts — into structured, exportable data. It integrates natively with Salesforce as a Connected App, enabling organisations to capture document data directly into Salesforce CRM objects.

Prepared by

ExonPro Innovations LLP

Date

March 2026

Table of Contents

1. Solution Overview
2. Architecture
3. Salesforce Integration
4. Data Flow — Scan to Salesforce
5. API Endpoints (Scan-Related)
6. Authentication & Security
7. Data Security & Encryption
8. Multi-Tenant Isolation
9. Input Validation & API Security
10. Infrastructure Security
11. Mobile Application Security
12. Components & Platforms

1. Solution Overview

xVio Scan is an AI-powered document scanning platform that transforms physical documents — business cards, invoices, receipts, ID documents, forms, and contracts — into structured, exportable data. It integrates natively with Salesforce as a Connected App, enabling organisations to capture document data directly into Salesforce CRM objects.

How It Works

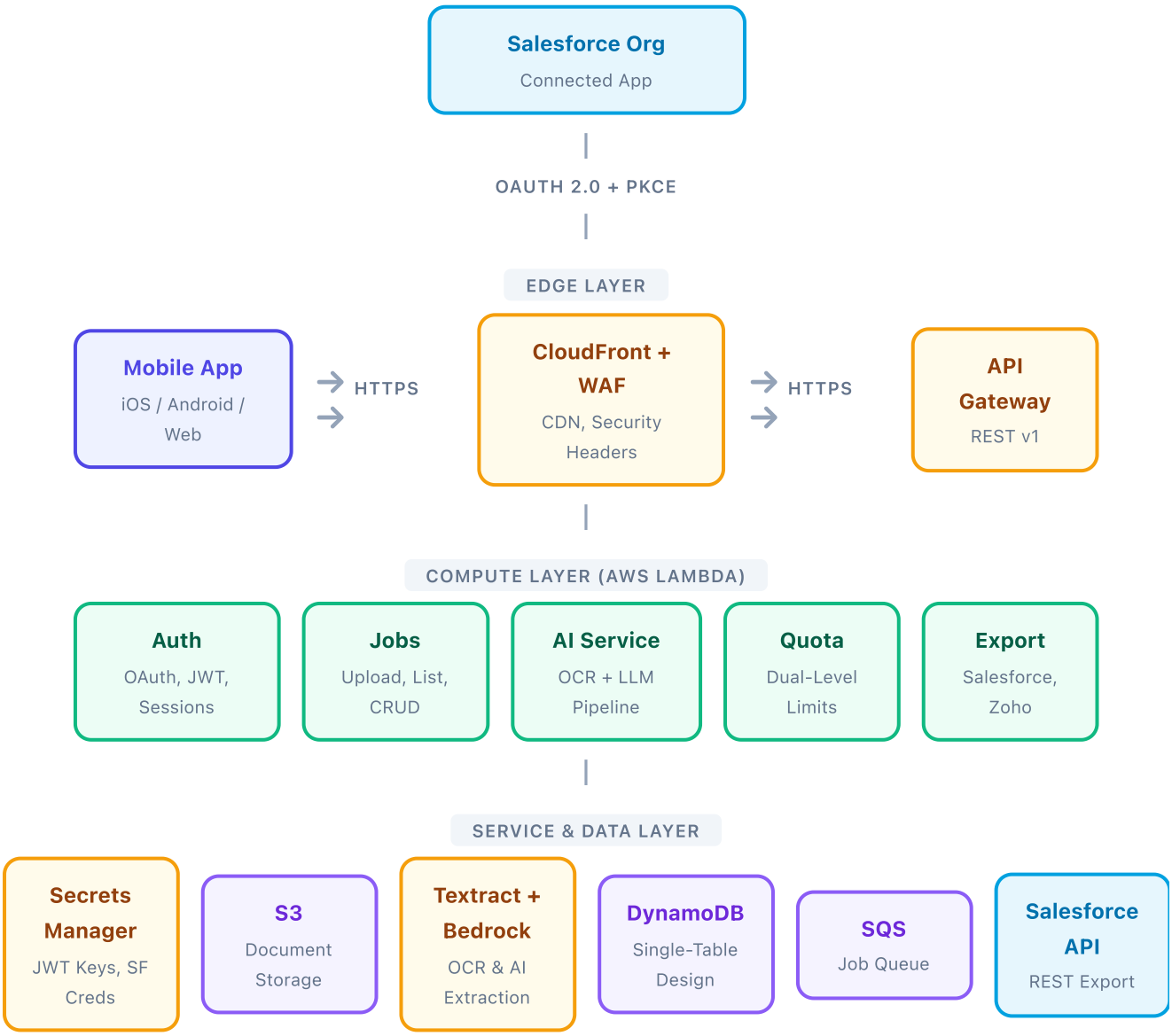
1. **Capture** — Users scan documents via mobile camera (iOS/Android) or upload images/PDFs from the web interface.
2. **OCR Extraction** — AWS Textract extracts raw text, layout, tables, and form fields from the document image.
3. **AI Field Extraction** — AWS Bedrock (LLM) parses the extracted text into structured fields (names, emails, phone numbers, addresses, invoice line items, etc.) using a configurable prompt template per document type.
4. **Auto Export** — Extracted data is automatically exported to Salesforce as Leads, Contacts, Cases, or custom objects with admin-configurable field mappings.

Key Capabilities

CAPABILITY	DESCRIPTION
Document Scanning	Business cards, invoices, receipts, ID documents, forms, contracts, handwritten notes
Two-Stage AI Pipeline	AWS Textract (OCR) + AWS Bedrock (LLM) for accurate structured extraction
Salesforce CRM Export	Direct export to Leads, Contacts, Cases, and custom sObjects with configurable field mappings
Campaign Attribution	Tag scans to Salesforce Campaigns for lead source tracking and ROI measurement
Offline Mode	Full scanning at trade shows and field sites — auto-syncs when connectivity is restored
Multi-Document Types	Configurable xVio Services — each with its own Textract API + AI model pipeline
Webhook & Email Export	Export extracted data via webhooks or email (Pro and Enterprise plans)

2. Architecture

xVio Scan is a **100% serverless application** built on AWS. No customer data leaves AWS infrastructure.



AWS Infrastructure Summary

COMPONENT	AWS SERVICE	PURPOSE
Compute	AWS Lambda (Node.js 20, ARM64)	All backend logic — auth, scanning, export, admin
API	API Gateway (REST)	HTTPS REST endpoints with WAF protection
Database	DynamoDB (single-table design)	All application data — tenants, users, scans, quotas
Storage	S3 (4 buckets)	Document uploads, exports, feedback, static assets
Queue	SQS	Async job processing (scan pipeline)
AI — OCR	AWS Textract	Document text, forms, tables, expense, and ID extraction
AI — LLM	AWS Bedrock (Converse API)	Structured field extraction from OCR output
CDN	CloudFront (2 distributions)	API caching + widget CDN distribution
WAF	AWS WAF v2	OWASP rules, rate limiting, IP reputation
Secrets	AWS Secrets Manager	JWT keys, Salesforce credentials (per-tenant)
Real-time	AppSync (GraphQL WebSocket)	Live scan status updates to clients
Auth (Admin)	Amazon Cognito	Admin console authentication
Monitoring	CloudWatch + CloudTrail	Logging, alerting, audit trail
IaC	AWS CDK (TypeScript)	Infrastructure as Code — all resources version-controlled

Region: All resources deployed in `ap-south-1` (Mumbai, India). No data replication outside this region.

3. Salesforce Integration

Connected App Configuration

SETTING	VALUE
OAuth Flow	Authorization Code with PKCE (RFC 7636, S256)
OAuth Scopes	`api` , `refresh_token` (minimal scopes only)
Callback URL	`https://api.xvio.ai/v1/tenant/auth/callback`
Consumer Key/Secret Storage	AWS Secrets Manager (per-tenant isolation)
Token Exchange	Server-side only (Lambda) — client never sees client_secret
Sandbox Support	Yes — `test.salesforce.com` for sandbox, `login.salesforce.com` for production
Org ID Validation	Salesforce `organization_id` from userinfo validated against tenant config

Salesforce Data Operations

OPERATION	DESCRIPTION
CRM Export	Create/update Leads, Contacts, Cases, or custom sObjects from scanned data
Field Mapping	Admin-configurable mapping from extracted fields to Salesforce object fields
Campaign Association	Optional campaign ID, field name, or SOQL query for lead attribution
Token Refresh	Automatic — on 401 from Salesforce API, refresh token is exchanged, re-encrypted, and stored
API Limit Handling	Retry with exponential backoff on rate limit errors; user-facing error messages on persistent failures

> **Data stored from Salesforce:** Only OAuth tokens (AES-256-GCM encrypted), instance URL (encrypted), and basic user profile (email, name). No Salesforce record data is persisted beyond the export operation.

4. Data Flow — Scan to Salesforce

1. **Upload** — Client sends document image (JPEG/PNG/PDF/TIFF, max 50MB) via `POST /tenant/jobs` or presigned S3 upload. File stored in S3 under `{tenantId}/{appId}/{jobId}/` prefix with SSE-S3 encryption.
2. **Queue** — Upload handler validates quota (dual-level: per-user + per-org), creates a DynamoDB job record, and pushes a message to the SQS Jobs queue.
3. **OCR** — The AI orchestrator Lambda consumes from SQS. Stage 1 calls AWS Textract (DetectDocumentText, AnalyzeDocument, AnalyzeExpense, or AnalyzeID depending on the service pipeline config).
4. **AI Extraction** — Stage 2 sends OCR text to AWS Bedrock via the Converse API. The LLM extracts structured fields based on a per-service prompt template. Output is validated against the service's field schema.
5. **Store** — Extracted data saved to DynamoDB. Real-time status update pushed to client via AppSync WebSocket subscription.
6. **Export** — User triggers export. The exporter Lambda authenticates to Salesforce using stored (encrypted) OAuth tokens, maps fields per admin config, and creates/updates the Salesforce record via REST API.
7. **Cleanup** — If `deleteSourceAfterProcessing` is enabled, the source image is deleted from S3 after successful processing.

ENCRYPTION AT EACH STAGE

STAGE	ENCRYPTION
Client → API	TLS 1.2+ (CloudFront enforced HTTPS)
S3 Storage	SSE-S3 (AES-256) + Block Public Access
DynamoDB Storage	AWS-managed encryption at rest
OAuth Tokens	AES-256-GCM application-level encryption
API → Textract/Bedrock	AWS SDK (TLS, IAM auth) — data stays within AWS
API → Salesforce	HTTPS (TLS 1.2+) via Salesforce REST API
Secrets Manager	KMS-managed encryption at rest

5. API Endpoints (Scan-Related)

The following endpoints are directly related to the document scanning and Salesforce export workflow. All tenant endpoints require JWT authentication (RS256). All admin endpoints require Cognito authorization.

Authentication Endpoints

METHOD	PATH	DESCRIPTION
POST	`/tenant/auth/login`	Initiate Salesforce OAuth 2.0 + PKCE login
GET	`/tenant/auth/callback`	Salesforce OAuth callback — exchange code for tokens
POST	`/tenant/auth/exchange`	One-time code exchange (mobile deep link, 60s TTL)
POST	`/tenant/auth/refresh`	Refresh JWT using refresh token
POST	`/tenant/auth/logout`	Invalidate session and revoke tokens
GET	`/tenant/auth/token`	Cookie-to-token exchange (AppSync auth)

Scanning & Jobs Endpoints

METHOD	PATH	DESCRIPTION
POST	`/tenant/jobs`	Upload document for scanning (base64)
POST	`/tenant/services/{serviceId}/upload-presigned`	Get presigned S3 URL for large file upload
GET	`/tenant/jobs`	List scanned documents (paginated)
GET	`/tenant/jobs/{jobId}`	Get scan details and extracted data
PUT	`/tenant/jobs/{jobId}`	Update extracted field values
DELETE	`/tenant/jobs/{jobId}`	Delete scan and associated S3 files
POST	`/tenant/jobs/{jobId}/retry`	Retry failed scan processing

Salesforce Export Endpoints

METHOD	PATH	DESCRIPTION
POST	`/tenant/ai/exporters/salesforce`	Export scan data to Salesforce CRM
GET	`/tenant/ai/exporters/history`	View export history

Supporting Endpoints

METHOD	PATH	DESCRIPTION
GET	`/tenant/quota`	Check remaining scan quota (user + org)
GET	`/tenant/services`	List available scanning services for this tenant
GET	`/tenant/campaigns`	List Salesforce campaigns for scan attribution
GET	`/tenant/notifications`	Get scan notifications
GET	`/tenant/system/health`	Health check endpoint

6. Authentication & Security

Authentication Methods

#	METHOD	FLOW	TOKEN TYPE
1	Salesforce OAuth 2.0 + PKCE	Authorization Code with S256 PKCE challenge	JWT (RS256)
2	Zoho OAuth 2.0	OAuth redirect with state validation	JWT (RS256)
3	AWS Cognito	USER_PASSWORD_AUTH flow	JWT (RS256)
4	API Key Exchange	X-API-Key + X-API-Secret headers	JWT (RS256, scoped)
5	Mobile Code Exchange	One-time code (60s TTL)	JWT + Refresh
6	Free Tier Signup	Cognito signup + 6-digit email verification	JWT (RS256)

JWT Configuration

SETTING	VALUE
Algorithm	RS256 (asymmetric)
Issuer	`api.xvio.ai`
Audience	`xvio-api`
Default Expiry	15 minutes (per-tenant configurable: 5–1440 min)
Key Storage	AWS Secrets Manager (5-min Lambda cache)
Claims	sub, email, tenantId, userId, type, jti
Token Types	`tenant_user`, `api_key`

Session Management

SETTING	VALUE
Refresh Token Format	UUID v4
Refresh Token Storage	SHA-256 hash in DynamoDB (plain token never stored)
Session Duration	180 days default (per-tenant configurable: 1–365 days)
Cookie: httpOnly	true (prevents XSS token theft)
Cookie: Secure	true (HTTPS only)
Cookie: SameSite	None (cross-domain with Secure flag)
Token Revocation	DynamoDB blacklist with 5-min cache, TTL matching token expiry

OAuth Security Controls

CONTROL	IMPLEMENTATION
PKCE	S256 challenge. Code verifier stored in DynamoDB with 10-min TTL. Deleted after exchange. Cannot be replayed.
CSRF Protection	`state` parameter: 32 bytes from `crypto.getRandomValues()`, stored in sessionStorage, verified on callback.
Org ID Validation	After callback, `organization_id` from Salesforce userinfo compared to tenant config. Mismatch = ACCESS DENIED + audit log.
One-Time Codes	Mobile auth uses 60-second one-time codes to prevent token leakage in URLs (SEC-015).
Redirect URI Allowlist	Zod validation: only `*.xvio.ai` (HTTPS) and `xvio://` (mobile deep link).
Rate Limiting	Login: 10/min, Callback: 20/min, Refresh: 30/min, Signup: 5/min — all per IP.

7. Data Security & Encryption

LAYER	METHOD	DETAILS
In Transit	TLS 1.2+	CloudFront enforces HTTPS. API Gateway HTTPS-only origin policy.
DynamoDB at Rest	AWS-managed encryption	Enabled on all tables across all environments.
S3 at Rest	SSE-S3 (AES-256)	`blockPublicAccess: BLOCK_ALL` on all buckets.
OAuth Tokens	AES-256-GCM	Application-level encryption. Format: `{iv:authTag:ciphertext}`. 16-byte random IV per encryption. Key from Secrets Manager.
Refresh Tokens	SHA-256 hash	Only the hash is stored. Plain token returned once at creation.
API Keys	SHA-256 hash + constant-time compare	Format: `exon_ak_{32 hex chars}`. First 12 chars visible for UI display only.
Secrets	AWS Secrets Manager (KMS)	JWT signing key, Salesforce creds, integration secrets. 5-min Lambda cache.

Data Handling Policies

- **No PII in logs** — Structured JSON logging with tenantId, userId, action, correlationId. No emails, names, or document content logged.
- **Source file deletion** — Configurable `deleteSourceAfterProcessing` flag per service. Diagnostic log retention: 7 days (dev), 365 days (prod).
- **API response masking** — Salesforce credentials masked in API responses (e.g., `3MVG9...***`). Tokens never returned in list/get endpoints.
- **Logout cleanup** — `clearAllData()` removes auth tokens, IndexedDB, localStorage, and sync cache from client.

8. Multi-Tenant Isolation

LAYER	ISOLATION MECHANISM
DynamoDB	Partition key always includes `TENANT#{tenantId}#APP#{appId}`. Cross-tenant queries are structurally impossible — not enforced by application logic, but by data architecture.
S3	Key prefix includes `{tenantId}/`. Access scoped per request.
JWT Claims	`tenantId` extracted from JWT token, never from request parameters. Cannot be spoofed without the signing key.
Secrets Manager	Per-tenant credential paths: `/xvio/{stage}/tenant/{tenantId}/sf-oauth`
Multi-App	`X-App-ID` header required. PK includes `APP#{appId}`.

9. Input Validation & API Security

Input Validation

CONTROL	IMPLEMENTATION
Schema Validation	Zod schema validation on all Lambda handler inputs before processing.
XSS Prevention	`sanitizeText()` strips HTML tags, javascript/data/vbscript URLs, and event handlers.
SQL Injection	DynamoDB (NoSQL) with parameterized ExpressionAttributeNames/Values. No raw string interpolation.
Open Redirect	`redirectUri` allowlisted to `*.xvio.ai`, `localhost`, `xvio://` only.
File Upload (Size)	Base64: 20MB limit. Presigned: 50MB limit. Enforced at Lambda level.
File Upload (Type)	MIME detection + extension check: JPEG, PNG, PDF, TIFF only.

API Protection

CONTROL	IMPLEMENTATION
AWS WAF v2	OWASP Common Rules, Known Bad Inputs, SQLi Rules, IP Reputation. Rate: 2000 req/5min (dev), 3000 req/5min (prod) per IP.
Application Rate Limiting	DynamoDB-based per-IP counters with TTL cleanup on all auth endpoints.
API Gateway Throttling	1000 req/min, 500 burst.
CORS	Explicit origin allowlist (no wildcard with credentials). Origins: `*.xvio.ai`, approved localhost ports.
Admin Routes	Cognito User Pool authorizer on all `/admin/*` endpoints.
Tenant Routes	JWT RS256 verification via `authorizeTenantRequest()` on all `/tenant/*` endpoints.
Security Headers	CloudFront Function: HSTS, X-Content-Type-Options, X-Frame-Options, X-XSS-Protection, Referrer-Policy, Permissions-Policy.

10. Infrastructure Security

CONTROL	STATUS	DETAILS
IAM Least Privilege	Done	Lambda roles scoped to specific table/bucket ARNs.
DynamoDB PITR	Done	Point-in-time recovery enabled on all tables, all environments. 1-hour RPO.
S3 Block Public Access	Done	`BLOCK_ALL` on all buckets. CDK default enabled.
CloudTrail	Done	API call auditing for all AWS operations.
CloudWatch Monitoring	Done	Alarms: Lambda errors (>0/5min), API 5xx (>5/5min), DDB throttles (>0/5min), SQS DLQ (>0).
SQS Dead Letter Queue	Done	Failed messages routed to DLQ after 3 retries. Alarm on DLQ depth.
VPC	N/A	Serverless architecture. All AWS services accessed via SDK with IAM auth. Edge protection via CloudFront + WAF.

11. Mobile Application Security

CONTROL	IMPLEMENTATION
Token Storage	Capacitor Preferences with OS-level encryption (iOS Keychain / Android EncryptedSharedPreferences)
OAuth Browser	iOS: ASWebAuthenticationSession. Android: Chrome Custom Tabs. Prevents redirect hijacking.
Deep Link Validation	`xvio://` scheme validated. One-time 60-second exchange codes for mobile deep links.
HTTPS Only	iOS ATS enforced. Android Network Security Config blocks cleartext traffic.

12. Components & Platforms

COMPONENT	TECHNOLOGY	DISTRIBUTION
Backend API	AWS Lambda (Node.js 20, TypeScript)	API Gateway REST
Web App	SvelteKit 2.0 (Progressive Web App)	`scan.xvio.ai`
iOS App	SvelteKit + Capacitor 6.2	App Store
Android App	SvelteKit + Capacitor 6.0	Google Play
Admin Console	SvelteKit 2.0	`console.xvio.ai`
Real-time	AppSync GraphQL (WebSocket)	Live scan status updates

Get in Touch

For questions about this document, security inquiries, integration support, or to schedule a technical walkthrough, please reach out to our team.

CONTACT SUPPORT

support@xvio.ai

ExonPro Innovations LLP

xvio.ai